

Incident Report

I have received an alert at 02:14 UTC alerting me of multiple failed login attempts made by the user j.martin followed by a successful one, marked as medium severity. I check the logs and the first thing I note is that the login attempts that have been made are during out-of-hours. Multiple failed login attempts point to brute force or credential stuffing, followed by multiple successful attempts, which requires further investigation. The location of the login attempts is Romania, and the device is marked as unknown. The successful attempts show that the MFA has been approved. I check the user's account history, and I notice he usually logs in from France/Belgium, by using company devices and usually between 8am to 7-9pm. I establish that it is possible to be account compromise as the user's usual login habits do not match – unfamiliar geolocation, unknown device, outside of normal login hours and multiple failed login attempts before success.

The helpdesk has contacted the user and he has confirmed that he was sleeping during this time, so he didn't attempt to log in; the MFA being successfully approved from the user's phone shows the attacker either compromised his device or used MFA fatigue, however the identity provider recorded only one push on the MFA request so there isn't enough evidence to reach that conclusion. The identity provider logs show that after logging in, the user first changed the password and then proceeded to change the email and logged in again. This has escalated the severity of the incident. The first things I did are to suspend the account and revoke all active session tokens, block the IP address, restore the original email address/contact information, change to a secure password, review the MFA methods and remove any unauthorised devices and preserve the logs. Next step is to scope the damage by investigating what the attacker did after gaining access. The activity shows that he accessed corporate email, opened Finance/Q4-Budget.xlsx and downloaded it, after that accessed and downloaded HR/Employee-Salaries.xlsx and added both files as an attachment sent to an external email address - finance.documents@protonmail.com. There is a significantly high confidentiality impact as the account was used to access, download and exfiltrate sensitive financial and employee salary information, potentially exposing the company to financial, privacy, regulatory, and reputational consequences.

As the final step – eradication and recovery, I've checked whether the attacker has left any backdoors. I checked privileged accounts to determine whether new accounts had been created or unauthorized changes have been made. I also checked for potential persistence mechanisms, including OAuth applications, new MFA methods, email forwarding rules, delegated permissions, scheduled tasks, and API tokens. After checking the employee's Microsoft 365 account, I've found a new inbox rule created at 2:26 UTC

Rule: if sender contains “password”, “security” or “MFA” → forward message to finance.documents@protonmail.com and mark as read.

This tells me that the attacker has created a persistence mechanism, to continue to access sensitive information and conceal messages from the user. After removing the malicious inbox rule, I have also looked for any other unauthorised rules and checked for external forwarding configurations and revoked API tokens again. Additional monitoring is required in case of more persistence. I have preserved the relevant logs and inbox rule as evidence.

Recommendations

- Implement a robust password policy and limit login attempts to reduce the risk of brute-force and password-guessing attacks.
- Use phishing-resistant MFA, such as passkeys or FIDO2 security keys, whenever possible.
- Require re-authentication or enhanced verification for sensitive actions, such as changes to passwords, recovery email addresses, or MFA methods.
- Implement least privilege to limit the actions a compromised account can perform.
- Monitor and control email forwarding rules, OAuth applications, delegated permissions, and other mechanisms that could be used to maintain unauthorized access.
- Encrypt sensitive data to minimize the impact of unauthorized access or exfiltration.
- Implement Data Loss Prevention (DLP) controls to detect and prevent the transmission of sensitive data to external recipients.